Host & Network Penetration Testing: Exploitation CTF 2 – Penetration Test Report

This report documents the exploitation process performed during the lab "Host & Network Penetration Testing: Exploitation CTF 2". The goal of the lab was to enumerate services, exploit vulnerabilities, and retrieve flags from the target machine. The attack chain demonstrates real-world penetration testing techniques such as SMB enumeration, pass-the-hash attacks, credential reuse, FTP abuse, and web shell exploitation.

Methodology 1. Service Enumeration – Identify exposed services on the target. 2. Credential Discovery – Extract credentials and NTLM hashes. 3. SMB Exploitation – Access network shares. 4. Password Reuse – Reuse discovered credentials on other services. 5. FTP Enumeration – Retrieve sensitive files from FTP. 6. Web Shell Upload – Upload ASP.NET web shell via FTP. 7. Remote Command Execution – Execute commands and retrieve system files.

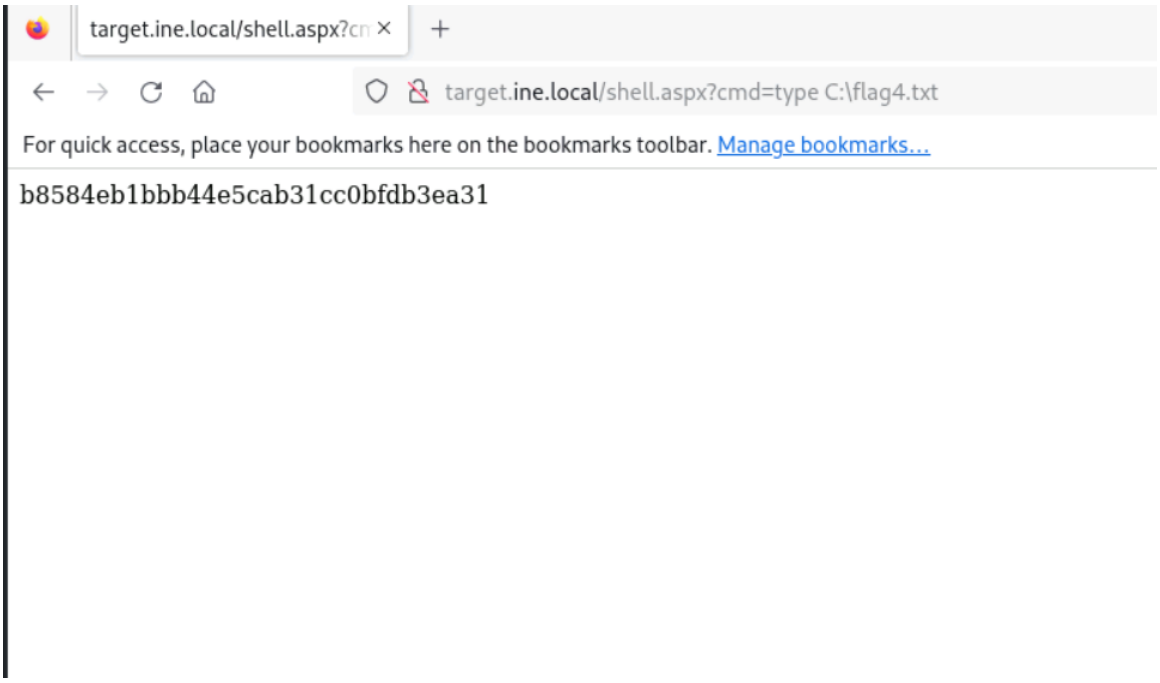
Flag 2 – SMB Share Exploitation After authenticating to SMB using discovered credentials, the ITResources share was accessed successfully. Inside the share, a file named flag2.txt was discovered and read, revealing the second flag.

```
    #  Name         Type          comment
    -  ----         ----          -------
    0  ADMIN$       DISK|SPECIAL  Remote Admin
    1  C$           DISK|SPECIAL  Default share
    2  D$           DISK|SPECIAL  Default share
    3  HRDocuments  DISK
    4  IPC$         IPC|SPECIAL   Remote IPC
    5  ITResources  DISK
    6  print$       DISK          Printer Drivers

SMB (10.5.30.21) > shares -i 3
[+] Successfully connected to HRDocuments
SMB (10.5.30.21\HRDocuments) > ls
[-] Error running command ls: RubySMB::Error::UnexpectedStatusCode The server responded with an unexpected status code: STATUS_ACCESS_DENIED
SMB (10.5.30.21\HRDocuments) >
SMB (10.5.30.21\HRDocuments) > shares -i 5
[+] Successfully connected to ITResources
SMB (10.5.30.21\ITResources) > ls
ls

    #  Type  Name       Created                   Accessed                  Written                   Changed                   Size
    -  ----  ----       -------                   --------                  -------                   -------                   ----
    0  DIR   .          2024-06-13T14:11:07+05:30  2024-06-13T14:45:46+05:30  2026-03-15T03:02:31+05:30  2026-03-15T03:02:31+05:30
    1  DIR   ..         2024-06-13T14:11:07+05:30  2024-06-13T14:45:46+05:30  2026-03-15T03:02:31+05:30  2026-03-15T03:02:31+05:30
    2  FILE  flag2.txt  2026-03-15T03:02:31+05:30  2026-03-15T03:02:31+05:30  2026-03-15T03:02:31+05:30  2026-03-15T03:02:31+05:30  34
    3  FILE  hint.txt   2024-06-13T14:45:39+05:30  2024-06-13T14:45:39+05:30  2024-06-13T16:00:47+05:30  2024-06-13T16:00:47+05:30  71

SMB (10.5.30.21\ITResources) > get flag2.txt
[-] Unknown command: get. Run the help command for more details.
SMB (10.5.30.21\ITResources) > cat flag2.txt
2d3a2454efeb44948c4cf8eafff5d173

SMB (10.5.30.21\ITResources) >
```

Flag 3 – FTP Credential Reuse The credentials discovered earlier were tested against the FTP service. The same password worked successfully. Username: david Password: omnitrix_9901 After logging in, a directory listing revealed the file flag3.txt which was downloaded and inspected to retrieve the third flag.

```
—# ftp target.ine.local
onnected to target.ine.local.
20 Microsoft FTP Service
ame (target.ine.local:root): david
31 Password required
assword:
30 User logged in.
emote system type is Windows_NT.
tp> ls
29 Entering Extended Passive Mode (|||49449|)
25 Data connection already open; Transfer starting.
6-13-24  10:36AM       <DIR>          aspnet_client
3-14-26  09:32PM                   34 flag3.txt
6-13-24  10:34AM                99710 iis-85.png
6-13-24  10:34AM                  701 iisstart.htm
26 Transfer complete.
tp> get flag3.txt
ocal: flag3.txt remote: flag3.txt
29 Entering Extended Passive Mode (|||49450|)
25 Data connection already open; Transfer starting.
00% |***********************************************************************
26 Transfer complete.
4 bytes received in 00:00 (9.55 KiB/s)
tp>
1]+  Stopped                 ftp target.ine.local

—(root㉿INE)-[~]
—# cat flag3.txt
f23876549d14073b5d487710ecddea9
```

Flag 4 – Web Shell Exploitation Because the FTP directory was linked to the IIS web server directory, an ASP.NET web shell was uploaded to the server. The web shell allowed execution of system commands through the browser. Using the command: type C:\flag4.txt The final flag stored in the root directory of the system was retrieved.



Conclusion This lab demonstrates several important penetration testing concepts: • SMB enumeration and share exploitation • Pass-the-hash authentication • Password reuse attacks • FTP service abuse • Web shell exploitation on IIS Security Recommendations: • Enforce strong password policies • Prevent credential reuse across services • Restrict FTP upload permissions • Validate uploaded files • Monitor suspicious command execution via web applications